ITAR Compliance in the Microsoft Cloud: Navigating GCC, Azure Commercial, and Azure Government



bryanlopez MICROSOFT
Mar 12, 2026

Why ITAR Compliance Matters in the Cloud

The International Traffic in Arms Regulations (ITAR) govern the export, temporary import, reexport, and transfer of defense articles, services, and related technical data directly related to defense articles listed on the United States Munitions List (USML) as well as furnishing defense services. Administered by the United States' Department of State's Directorate of Defense Trade Controls (DDTC), the ITAR imposes strict requirements on manufacturers, exporters, and brokers of defense-related items - and those requirements extend to how and where ITAR-controlled data is stored, processed, and accessed in the cloud.

For federal agencies, Defense Industrial Base (DIB) organizations, and government contractors, choosing the right Microsoft cloud environment is not just a technical decision - it is a compliance imperative. Getting it wrong can result in civil penalties, criminal prosecution, loss of export privileges, and the erosion of trust with federal partners. It can even cause the government to bar companies from federal contracts.

This guide walks through how ITAR compliance maps to our cloud offerings - specifically Microsoft 365 GCC, Azure Commercial, and Azure Government - drawing exclusively from official Microsoft documentation to help you make informed decisions about where your ITAR-controlled workloads belong.

Understanding ITAR: Core Requirements

Before evaluating cloud environments, it is essential to understand what the ITAR requires:

- **Registration with DDTC:** Organizations that manufacture, export, or broker defense articles must register with the Directorate of Defense Trade Controls.
- **Access Restricted to US Persons:** ITAR-controlled technical data may only be accessed by US persons unless specific DDTC authorization has been granted.
- **Prohibition on Unauthorized Export:** ITAR-controlled technical data may not be exported - included by making it available to foreign person – without authorization from the DDTC. As described in additional detail below, the ITAR does not impose an affirmative requirement that data be stored within the Continental United States (CONUS). However, storing data within CONUS and restricting access to U.S. persons is a widely adopted mitigation strategy. **End-to-End Encryption:** The revised ITAR rules, effective March 25, 2020, introduced a carve-out stating that sending, taking, or storing unclassified technical data does not constitute an export if the data is secured using end-to-end encryption with FIPS 140 compliant cryptographic modules, the means of decryption are not provided to any person other than the intended recipient, and the data is not intentionally sent to or stored in a proscribed country listed under 22 CFR § 126.1. Additionally, there are specific requirements for protecting and sharing access information for ITAR data to qualify for the carve-out.

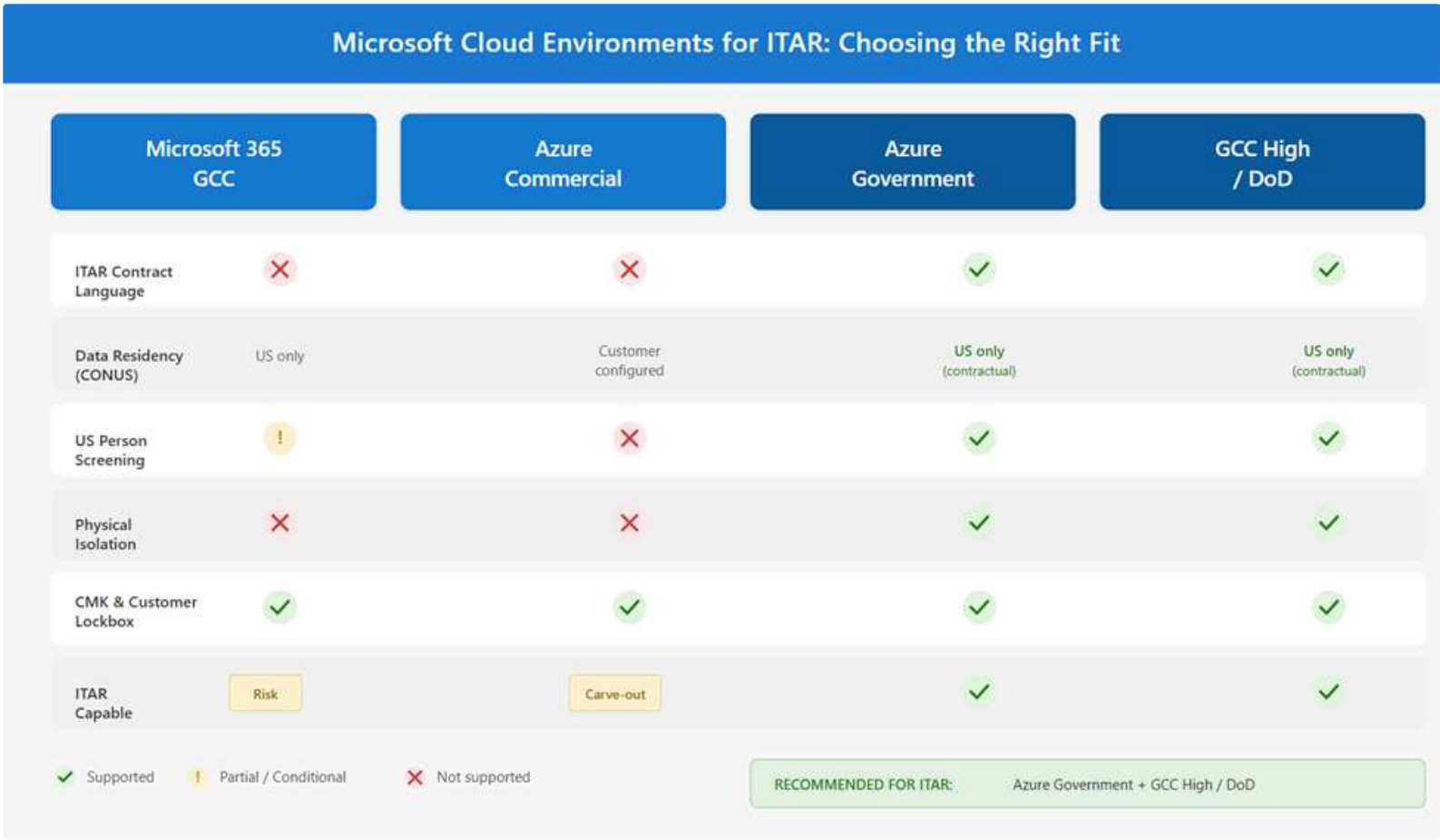
Think of ITAR requirements as a vault within a vault. It is not enough that the building is secure — the room, the safe, and the access list all have to meet the standard independently.

There Is No ITAR Certification

A critical point that often creates confusion: **there is no ITAR compliance certification for cloud service providers.** We design and operate our in-scope services to be capable of supporting your ITAR obligations and compliance program, but there is no formal ITAR certification to obtain. This means that ITAR compliance is ultimately the responsibility of the data owner — we provide the capable platform, and you are responsible for the protection, architecture, and access controls within your environment.

Reference: [International Traffic in Arms Regulations (ITAR) - Azure Compliance | Microsoft Learn]

Microsoft Cloud Environments: Where Does ITAR Fit?



Microsoft 365 GCC

Microsoft 365 Government Community Cloud (GCC) is designed for US federal, state, local, and tribal government entities, along with contractors holding or processing data on behalf of the US Government. GCC provides compliance with FedRAMP High, DFARS, and requirements for criminal justice and federal tax information systems.

However, GCC does not natively support ITAR or EAR-controlled data. While GCC stores data within the United States and restricts access to screened personnel, it runs on Microsoft Entra ID Commercial. Support staff may include non-US persons, and we will only agree to ITAR contract language for the GCC High environment - not standard GCC.

Can Compensating Controls Make GCC Viable for ITAR? A Risk-Based Decision

We recognize that not every organization is positioned to leverage to GCC High - whether due to budget constraints, licensing timelines, or operational complexity. For organizations evaluating GCC, it is worth understanding the compensating controls available, the case they enable, and efforts need to reduce risk within their organization.

The core argument for GCC viability rests on four points:

1. **Data never leaves the United States.** GCC stores all customer data within US boundaries. Unlike Azure Commercial, where data residency depends on customer configuration, GCC's CONUS data residency is part of the environment boundary itself.
2. **No unauthorized human access.** When CMK and Customer Lockbox are implemented together, they eliminate the risk of unauthorized human access to ITAR-controlled data — regardless of the background check status of any individual. CMK ensures that we and our agents cannot decrypt your data without keys your organization controls. Customer Lockbox ensures that in rare instances where our support engineers need elevated access, you explicitly approve or reject every request.
3. **Automated processing stays within the GCC boundary in CONUS.** Automated service operations that process your data remain within the GCC environment and do not leave the United States.
4. **Therefore, no export occurs.** If the data never leaves the US, no Microsoft employee can access it in decrypted form without explicit customer approval, and all processing remains within CONUS - the conditions that would constitute an export under ITAR are not met.

Customer Managed Keys (CMK): GCC supports customer-managed encryption keys through Azure Key Vault. With CMK, your organization retains exclusive control of the encryption keys that protect your data at rest. Because Azure Key Vault is designed so that we and our agents cannot see or extract your cryptographic keys, CMK is a critical component of meeting the ITAR end-to-end encryption carve-out requirement that the means of decryption are not provided to any third party. This is the critical control - even if a non-US person were to encounter the encrypted data, nothing is revealed because they cannot decrypt it without your keys.

Customer Lockbox: Customer Lockbox for Microsoft 365 provides an explicit access governance gate. In rare instances where our support engineers need elevated access to your data to resolve a service request, Customer Lockbox requires your approval before any access is granted. This gives your organization direct control over who touches your data and when — making the background check status of individual support personnel a secondary concern, because no human access occurs without your authorization.

This is fundamentally a risk-based decision - and one that typically falls to the CISO and organizational leadership to approve and be held accountable for. Organizations that implement CMK and Customer Lockbox in GCC can build a defensible technical case that no export occurs, but they should ensure that decision is documented, reviewed by compliance stakeholders, and aligned with their organization's risk tolerance. For many organizations — particularly those in the DIB handling ITAR-controlled technical data — GCC High will remain the appropriate path because it eliminates these considerations by design.

Bottom line: Ultimately, it is incumbent on the data owner to decide what tools meet their purposes. GCC is suitable for Federally Controlled Information (FCI) and certain categories of Controlled Unclassified Information (CUI). Organizations with ITAR-controlled data may prefer GCC High or DoD environments, but CMK and Customer Lockbox can serve as meaningful compensating controls for organizations managing the transition or making a documented, risk-based determination that the technical controls in GCC are sufficient for their specific use case.

Reference: Office 365 US Government - Service Descriptions | Microsoft Learn

Azure Commercial

Azure Commercial can play a role in supporting ITAR compliance — but with an important distinction from our government cloud environments: **the compliance boundary in Azure Commercial is customer-implemented rather than environment-guaranteed.**

Both Azure and Azure Government can help you meet your ITAR compliance obligations. Our Azure datacenters (except for the Hong Kong SAR region) are not located in proscribed countries or the Russian Federation. Azure services rely on FIPS 140 validated cryptographic modules and provide multiple options for encrypting data in transit and at rest, including customer-managed keys (CMK) through Azure Key Vault backed by FIPS 140 validated HSMs.

Data Residency in Azure Commercial

While Azure Commercial is not hard-locked to CONUS the way Azure Government is, we provide you with the tools and transparency to control where your data resides. You select the Azure region where your applications and data are deployed. Most Azure services enable you to specify the region where your customer data will be stored and processed, and we will not store or process customer data outside the selected geography. We publish a data residency page and per-service documentation that identifies which services store data at rest in-region and which have global components that may process data outside the selected geography.

To enforce data residency in Azure Commercial, you can leverage region selection during deployment, Azure Policy to restrict resource creation to specific US regions, and service-specific residency controls documented for each service. It is your responsibility to review per-service documentation to understand which services are fully regional and which may have global processing components, and to architect your environment accordingly.

This is the fundamental difference: **in Azure Government, the CONUS boundary is part of the environment. In Azure Commercial, you are building that boundary yourself through policy, encryption, access controls, and deliberate architecture choices for the available localized services.**

The Encryption Carve-Out

The key enabler for ITAR in Azure Commercial is the **ITAR end-to-end encryption carve-out.** The ITAR states that storing encrypted technical data does not constitute an export when the data is unclassified, encrypted end-to-end with FIPS 140 compliant modules, and not intentionally stored in a proscribed country. Also, the means of encryption must not be provided to a third party. Azure Key Vault is designed so that Microsoft and its agents cannot see or extract customers' cryptographic keys. Customer Lockbox for Azure puts you in charge of approving or rejecting any elevated access requests from our support engineers, providing an additional layer of access governance.

However, Azure Commercial does not provide the additional contractual commitments that Azure Government offers, such as guaranteed storage within the United States and access limited exclusively to screened US persons. The compliance controls are available to you - but the responsibility for implementing, configuring, and maintaining them rests entirely with your organization.

Bottom line: Azure Commercial can support ITAR workloads under the encryption carve-out, but you are building and enforcing the compliance boundary yourself. Most organizations with ITAR obligations are best served by Azure Government, where the boundary is built into the environment.

Reference: International Traffic in Arms Regulations (ITAR) - Azure Compliance | Microsoft Learn

Azure Government

Azure Government is a physically and logically isolated cloud environment built specifically for US government agencies and their partners. Data transmission and processing are restricted to CONUS, and access to systems processing customer data is limited to screened US persons. Azure Government provides contractual commitments regarding data residency and personnel access that go beyond what Azure Commercial offers.

Azure Government holds FedRAMP High authorization and supports DISA SRG Impact Level 5 (IL5), ITAR, and Export Administration Regulations (EAR). For organizations that need to store and process ITAR-regulated data, Azure Government provides the strongest alignment with ITAR requirements available in our cloud ecosystem.

Key capabilities that support ITAR compliance in Azure Government include:

- **Data location control:** Robust tools to restrict data storage to US regions, ensuring customer data is not intentionally stored in a non-conforming location.
- **Access controls:** Our technical support personnel do not have default access to customer data. Customer Lockbox for Azure enables you to approve or reject any elevated access requests.
- **End-to-end encryption:** FIPS 140 validated cryptographic modules with customer-managed key options through Azure Key Vault HSMs.
- **Screened US citizens:** Personnel with potential access to customer data undergo verification of US citizenship and additional background screening. This is more than what the ITAR requires, which is a US person.

Bottom line: Azure Government is the recommended environment for ITAR-**controlled** workloads and provides the strongest contractual and technical protections.

Reference: Azure support for export controls | Microsoft Learn

Microsoft 365 GCC High and DoD

For organizations that need Microsoft 365 productivity services (Exchange, SharePoint, Teams, OneDrive) alongside ITAR compliance, **GCC High is the appropriate environment.** GCC High is built on Azure Government infrastructure, stores data exclusively in US data centers, and limits access to screened US citizens. We will agree to ITAR contract language for the GCC High environment.

The Office 365 GCC High and DoD environments deliver compliance with Department of Defense Security Requirements Guidelines, DFARS, and ITAR. You must sign additional agreements notifying us of your intention to store ITAR-controlled data so that we can comply with our obligations to both you and the US government.

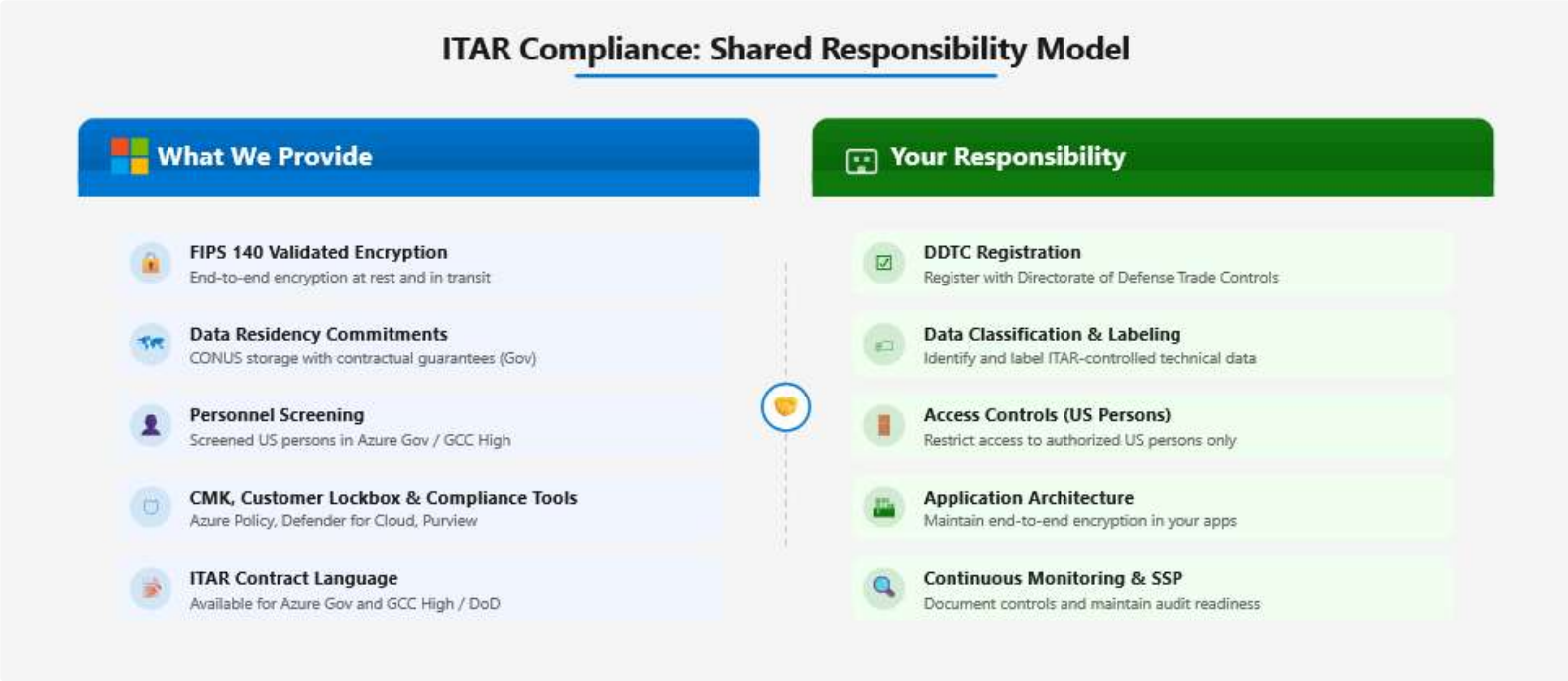
Reference: Office 365 GCC High and DoD - Service Descriptions | Microsoft Learn

Comparing the Environments at a Glance

Capability	GCC	Azure Commercial	Azure Government	GCC High / DoD
ITAR Contract Language	No	No	Yes	Yes
Data Residency (CONUS)	US only (environment boundary)	Customer-configured via region selection, Azure Policy, and per-service residency controls	US only (contractual)	US only (contractual)
Compliance Boundary	Environment-guaranteed	Customer-built through policy, encryption, and architecture	Environment-guaranteed	Environment-guaranteed
Personnel Screening (US Persons)	Screened personnel, but support staff may include non-US persons	No specific commitment	Screened US persons	Screened US citizens
Physical/Logical Isolation	Logical segregation on Azure Commercial	Shared commercial infrastructure	Physically isolated	Physically isolated (Azure Gov)
FIPS 140 Encryption	Yes	Yes	Yes	Yes
Customer Managed Keys (CMK)	Yes (Azure Key Vault)	Yes (Azure Key Vault)	Yes (Azure Key Vault)	Yes (Azure Key Vault)
Customer Lockbox	Yes	Yes	Yes	Yes
FedRAMP Authorization	FedRAMP High	Varies by service	FedRAMP High	FedRAMP High

ITAR-Capable	Not natively; CMK + Customer Lockbox enable a defensible no-export case (risk-based decision)	Under encryption carve-out (customer-built boundary)	Yes	Yes

Shared Responsibility: Your Role in ITAR Compliance



Regardless of which cloud environment you choose, ITAR compliance is a shared responsibility. We provide the platform capabilities — encryption, data residency, access controls, and personnel screening — but your organization is responsible for:

- **Registering with DDTC** if you manufacture, export, or broker defense articles.
- **Classifying and labeling data** to identify ITAR-controlled technical data.
- **Configuring access controls** to ensure only authorized US persons can access regulated information.
- **Signing additional agreements** with us to formalize your intention to store ITAR-controlled data (required for Azure Government and GCC High).
- **Designing application architecture** to maintain end-to-end encryption that meets ITAR requirements. We do not inspect, approve, or monitor your applications.
- **Managing third-party integrations** that may fall outside the compliance boundary.

The Microsoft Enterprise Agreement Amendment enables us and the customer to work together in reporting ITAR violations, fulfilling the specific reporting obligations that ITAR requires.

Reference: [International Traffic in Arms Regulations (ITAR) - Microsoft Compliance | Microsoft Learn]

Action Plan for Getting Started



- **Step 1: Assess Your Data** Determine whether your organization handles defense articles, services, or technical data on the USML. Understand which data is ITAR-controlled and map your data flows.

  Step 2: Choose the Right Environment For ITAR-**controlled** workloads, Azure Government and Microsoft 365 GCC High provide the strongest alignment. If you are evaluating GCC with compensating controls like CMK and Customer Lockbox, or Azure Commercial under the encryption carve-out, ensure the decision is documented and approved by your CISO and compliance stakeholders — as the CISO is ultimately accountable for the risk acceptance and the defensibility of the chosen approach.

  Step 3: Engage Your Microsoft Account Team If you are seeking to host ITAR-**controlled** data, work with your Microsoft account and licensing teams to obtain proper agreements and access relevant system architecture information.

  Step 4: Develop Your Compliance Architecture Leverage tools like Azure Policy, Microsoft Defender for Cloud, Microsoft Purview Compliance Manager, and Customer Lockbox to enforce and monitor your compliance posture.

  Step 5: Document and Maintain Develop a System Security Plan (SSP) that reflects your ITAR controls, and continuously monitor and update your controls as your environment evolves.

  Resources and Further Reading

  - International Traffic in Arms Regulations (ITAR) - Azure Compliance | Microsoft Learn
  - Azure support for export controls | Microsoft Learn
  - International Traffic in Arms Regulations (ITAR) - Microsoft Compliance | Microsoft Learn
  - Office 365 US Government - Service Descriptions | Microsoft Learn
  - Office 365 GCC High and DoD - Service Descriptions | Microsoft Learn
  - Azure Data Residency
  - Microsoft Azure Export Controls Whitepaper
  - Microsoft Government Compliance Offerings
  - DDTC ITAR Landing Page
  - ITAR Title 22 CFR Part 120-130

Conclusion

ITAR compliance in the cloud is achievable - but it requires deliberate environment selection, proper contractual agreements, and disciplined architecture. Microsoft 365 GCC does not natively support ITAR, but Customer Managed Keys and Customer Lockbox can enable a defensible technical case that no export occurs - a risk-based decision that falls to the CISO and organizational leadership to approve. Azure Commercial can support ITAR under the encryption carve-out, but the compliance boundary is customer-built rather than environment-guaranteed, which demands careful architecture and per-service

residency review. Azure Government and GCC High provide the contractual commitments, data residency guarantees, and personnel screening that most closely align with ITAR requirements — with the compliance boundary built into the environment by design.

The path forward starts with understanding your data, choosing the right environment, and building your compliance architecture on our capable platform.

Join the Discussion

Join the conversation below to ask questions, share deployment insights, and connect with other public sector professionals working with Microsoft capabilities. Your feedback and experience help strengthen the community.

Updated Mar 20, 2026 VERSION 3.0